Security & Privacy Disclosure, Final Report

ID Austria (at.gv.oe.app) v5.5.0

The national eID application for nine million Austrians hardcodes a Firebase API key and initializes Firebase plus Google ML Kit before the device is even unlocked, while official tax, social-security, and registration notices route through Google infrastructure in the United States with no documented transfer safeguard, unresolved through 120 days and a delivery chain that bounced three times before reaching a human inbox at all

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, FOUR FINDINGS REMAIN UNADDRESSED

Target	Republik Österreich, Bundeskanzleramt / Digitales Amt (Bunde srechenzentrum, BRZ)
Package	at.gv.oe.app (ID Austria)
Version Audited	v5.5.0 (versionCode 2026052703, built 2026-05-27)
Platform Audited	Android, static analysis of the production APK, SHA-256 00bac 31cbde35cca3c8be7a2547b3caf5e0b78d600707490d7f2e0e 4ad92d0e8
Initial Disclosure (R1)	2026-06-19, to sicherheit@digitalesamt.gv.at — bounced per- manently 2026-06-23
First Confirmed Delivery	2026-08-04, to datenschutz@bka.gv.at, CC post.szrb@bka. gv.at, dsb@dsb.gv.at, cert@cert.at, after two further bounced attempts (2026-06-27, 2026-06-30)
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	CRITICAL
Findings	4 of 6 original findings closed on (2 Critical, 2 High); 2 Medium and 1 Low from the original disclosure remain on file
Correspondence	5 messages sent by RFI-IRFOS across four delivery attempts, 0 substantive replies ever received from the Bundeskanzleramt or the Digitales Amt
Authorities CC'd	Austrian Datenschutzbehoerde (dsb@dsb.gv.at) · CERT.at (cert@cert.at)

security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6

4.1 C1: Hardcoded Firebase API key for the national eID app's backend project, enabling impersonation and denial-of-service against nine million citizens . . . 6

4.2 C2: Firebase and Google ML Kit initialize before the device is unlocked, transmitting data to Google before any citizen interaction on the national eID app . 7

4.3 H1: Official government notices (tax, social security, registration) route through Google Firebase Cloud Messaging in the United States with no documented transfer mechanism 8

4.4 H2: Device-policy lock-credential permission combined with boot-time autostart on a pre-unlock-initializing national eID app 9

5 Impact Analysis 9

6 The Complete Chain: A Disclosure That Bounced Three Times Before Reaching a Human Inbox at All 10

7 Data Protection – Article by Article 11

8 Regulatory & Legal Landscape 11

9 Indicators of Compromise 12

10 Disclosure Timeline & Outcome 12

11 Residual Risk & Recommendations 13

Executive Summary

ID Austria is the national digital-identity application operated by the Republik Österreich through the Bundeskanzleramt and its Digitales Amt (technically operated by the Bundesrechenzentrum). Nine million Austrians can activate this application as their legal digital identity, qualified electronic signature, and health-record (ELGA) access point. A static analysis of the production Android binary (v5.5.0) identified six findings in total; four of them, two CRITICAL and two HIGH, remain the subject of this closure.

The production APK hardcodes a Firebase API key for the 'digitalesamt' project directly in res/values/strings.xml. If the key is not certificate-restricted, it enables quota-exhaustion denial of service against all ID Austria users, impersonation of official push notifications ('your tax assessment is ready, open now'), user enumeration via Firebase's identity toolkit, and potential access to the Realtime Database and Cloud Storage bucket behind the app, none of which requires touching any server RFI-IRFOS does not control (C1). Separately, both the Firebase SDK and Google ML Kit are declared directBootAware="true" in the manifest, meaning they initialize and transmit device data to Google LLC in the United States before the device is even unlocked, before the citizen has taken any action at all, on an application used for state authentication, eIDAS-qualified signatures, and ELGA health-record access (C2). Official government notices, tax assessments, social-security correspondence, and registration-office communications, are confirmed in the app's own privacy text to route through Firebase Cloud Messaging, meaning metadata of Austrian state administration transits Google's US infrastructure with no documented Art. 44-49 transfer mechanism identified (H1). Finally, the app declares MANAGE_DEVICE_POLICY_LOCK_CREDENTIALS alongside RECEIVE_BOOT_COMPLETED, a sensitive device-policy permission combination active from first boot alongside the pre-unlock Firebase initialization in C2 (H2).

RFI-IRFOS's original disclosure, sent 19 June 2026 to sicherheit@digitalesamt.gv.at with CC to A-Trust (which operates the signature library embedded in the app) and BCC to the Austrian Datenschutzbehoerde and CERT.at, bounced permanently within four days. Two further corrected-delivery attempts, 27 and 30 June 2026, to post@/datenschutz@/kommunikation@digitalesamt.gv.at, also bounced permanently. The disclosure first reached a live inbox on 4 August 2026, 46 days after the original attempt, when RFI-IRFOS redelivered it to datenschutz@bka.gv.at, the Bundeskanzleramt's published data-protection contact, CC post.szrb@bka.gv.at, the Austrian Datenschutzbehoerde, and CERT.at. A follow-up on 3 September 2026 restated all open questions. Across 74 days since the first confirmed delivery, and 120 days since the original disclosure attempt, the Bundeskanzleramt and the Digitales Amt have never substantively replied. A-Trust, the only party to respond at all, did so in a separate, already-published case concerning its own signature-library product, and explicitly attributed two of the shared findings to the BRZ's responsibility, an attribution the BRZ itself has never confirmed.

ID	Severity	Title
C1	CRITICAL	Hardcoded Firebase API key for the national eID app's backend project, enabling impersonation and denial-of-service against nine million citizens
C2	CRITICAL	Firebase and Google ML Kit initialize before the device is unlocked, transmitting data to Google before any citizen interaction on the national eID app

ID	Severity	Title
H1	HIGH	Official government notices (tax, social security, registration) route through Google Firebase Cloud Messaging in the United States with no documented transfer mechanism
H2	HIGH	Device-policy lock-credential permission combined with boot-time autostart on a pre-unlock-initializing national eID app

Subject & Operator Context

ID Austria is the Republik Österreich's national digital-identity system, operated through the Bundeskanzleramt and its Digitales Amt (Bundesrechenzentrum). It replaces the earlier Handy-Signatur and serves as the legal digital identity for qualified electronic signatures under eIDAS, government-service authentication, and health-record (ELGA) access for Austria's population of roughly nine million. The app embeds the at.atrust.mobsig.library signature library operated by A-Trust, which has its own, separate, already-published disclosure case (A-Trust Signatur App, published 2026-09-18); this report concerns ID Austria itself, operated by the Bundeskanzleramt, not A-Trust's own product.

Engagement Summary

RFI-IRFOS sent the original disclosure on 19 June 2026 to sicherheit@digitalesamt.gv.at, CC office@a-trust.at and sales@a-trust.at (so A-Trust could independently assess the findings affecting its signature library), BCC the Austrian Datenschutzbehoerde and CERT.at. The address bounced with repeated delivery delays from 20 to 22 June, then a permanent failure on 23 June 2026. The disclosure never reached a human inbox on this attempt.

A corrected redelivery on 27 June 2026 to post@digitalesamt.gv.at, CC datenschutz@digitalesamt.gv.at and pressedienst@bka.gv.at, bounced immediately at pressedienst@bka.gv.at and permanently at the other two addresses by 3 July. A second corrected redelivery on 30 June 2026 to datenschutz@digitalesamt.gv.at and kommunikation@digitalesamt.gv.at also bounced permanently by 3 July. Three attempts, four weeks, zero successful deliveries to any digitalesamt.gv.at address.

The disclosure first reached a live inbox on 4 August 2026, when RFI-IRFOS redelivered the complete findings to datenschutz@bka.gv.at, the data-protection contact published on id-austria.gv.at itself, CC post.szrb@bka.gv.at, the Austrian Datenschutzbehoerde, and CERT.at. No bounce followed; this is the first confirmed delivery. A follow-up on 3 September 2026, 30 days after confirmed delivery, restated the three original yes/no questions and set a response deadline of 17 September 2026. That deadline passed, as did the 28 September 2026 embargo stated in the redelivered disclosure. Across five messages sent and four delivery attempts, the Bundeskanzleramt and the Digitales Amt have never substantively replied.

Findings

C1: Hardcoded Firebase API key for the national eID app's backend project, enabling impersonation and denial-of-service against nine million citizens

CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:H/VA:H/SC:N/SI:N/SA:N, 8.7) — key extraction enables quota-exhaustion DoS, push-notification impersonation of official government notices, user enumeration, and potential database/storage access, blast-radius escalation: RFI-IRFOS raises this from the original disclosure's MEDIUM rating because the key sits behind a system serving nine million citizens as their sole legal digital identity, where impersonated push notifications or a denial-of-service event carry state-infrastructure consequences a typical consumer app's identical finding would not

```
google_api_key: AIzaSyCLu46GzFY6qxDpR_6MxsDDA_HK30-EVXM
google_crash_reporting_api_key: AIzaSyCLu46GzFY6qxDpR_6MxsDDA_HK30-EVXM
firebase_database_url: https://digitalesamt.firebaseio.com
google_storage_bucket: digitalesamt.appspot.com
project_id: digitalesamt
google_app_id: 1:753655444199:android:7cc7879a866c0d58
default_web_client_id: 753655444199-gjh66ccr6okpohcqojb7b63te3e363ub.apps.
    googleusercontent.com

Certificate-restricted in Google Cloud Console: not confirmed by the operator
```

Impact: The production APK hardcodes a Firebase API key (AIzaSyCLu46GzFY6qxDpR_6MxsDDA_HK30-EVXM) for the 'digitalesamt' Firebase project in res/values/strings.xml, alongside the project's database URL, storage bucket, app ID, and OAuth client ID. If this key is not certificate-restricted in Google Cloud Console to the production APK's signing fingerprint, RFI-IRFOS identified five concrete attacks reachable without touching any server: quota-exhaustion denial of service against the Firebase API itself, blocking authentication for all ID Austria users; impersonation of official government push notifications ('your tax assessment is ready, open now') with no malware required; user enumeration via Firebase's identitytoolkit.googleapis.com endpoint to harvest which email addresses are registered; and, if security rules are default or misconfigured, direct read access to the Realtime Database and Cloud Storage bucket behind Austria's digital-government backend. The burden of demonstrating none of these attacks is viable rests with the operator, not with RFI-IRFOS, per GDPR Art. 5(2).

C2: Firebase and Google ML Kit initialize before the device is unlocked, transmitting data to Google before any citizen interaction on the national eID app

CRITICAL (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N, 6.9) — device data reaches Google LLC in the United States before the device is unlocked, blast-radius escalation: RFI-IRFOS raises this from a routine pre-consent finding because the app in question is the state's sole legal digital identity and ELGA health-record access point, not a typical consumer app

```
<provider
  android:authorities="at.gv.oe.app.firebaseinitprovider"
  android:directBootAware="true"
  android:initOrder="100"
  android:name="com.google.firebase.provider.FirebaseInitProvider" />

<provider
  android:authorities="at.gv.oe.app.mlkitinitprovider"
  android:directBootAware="true"
  android:initOrder="99"
  android:name="com.google.mlkit.common.internal.MlKitInitProvider" />
```

Impact: The manifest declares both the Firebase content provider and the Google ML Kit content provider with android:directBootAware="true" and explicit initOrder values, meaning both initialize automatically while the device is still in its direct-boot, locked state, before the user has unlocked the device or interacted with the app in any way. For an application that serves as a citizen's state-issued digital identity, qualified electronic signature mechanism, and gateway to ELGA health records, device data reaching Google LLC's US infrastructure before any user action raises a direct Art. 6(1) lawful-basis question: no interaction has occurred that could constitute consent, and no alternative legal basis is documented for this specific pre-interaction transmission.

H1: Official government notices (tax, social security, registration) route through Google Firebase Cloud Messaging in the United States with no documented transfer mechanism

HIGH (CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:L/SI:N/SA:N, 4.5) — metadata of Austrian state administrative communications transits US infrastructure with no identified Art. 44-49 safeguard

```
privacy text (pp_section_3_3_8_0): "push-nachrichten (notifications) der app
  werden ueber firebase cloud messaging (FCM) versendet"

android.permission.RECEIVE_BOOT_COMPLETED
android.permission.FOREGROUND_SERVICE

Documented Art. 44-49 transfer mechanism for this specific purpose: not identified
```

Impact: The app's own privacy text (pp_section_3_3_8_0) confirms that push notifications for the ID Austria app are delivered via Firebase Cloud Messaging, operated by Google LLC in the United States. Combined with the RECEIVE_BOOT_COMPLETED and FOREGROUND_SERVICE permissions supporting autostart for government push delivery, this means metadata of official notices, tax assessments, social-security correspondence, and registration-office communications, transits US infrastructure. RFI-IRFOS could not identify a documented Standard Contractual Clause or adequacy-decision basis specific to this processing purpose anywhere in the operator's available disclosures.

H2: Device-policy lock-credential permission combined with boot-time autostart on a pre-unlock-initializing national eID app

HIGH (CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:L/SC:N/SI:N/SA:N, 5.0) — a sensitive device-policy permission profile is active from first boot, alongside pre-unlock Google infrastructure initialization documented in C2

```
<uses-permission android:name="android.permission.
    MANAGE_DEVICE_POLICY_LOCK_CREDENTIALS"/>
<uses-permission android:name="android.permission.REQUEST_PASSWORD_COMPLEXITY"/>
<uses-permission android:name="android.permission.RECEIVE_BOOT_COMPLETED"/>

Published Art. 35 DPIA covering this permission profile combined with C2: not
    identified
```

Impact: The app declares both android.permission.MANAGE_DEVICE_POLICY_LOCK_CREDENTIALS, which allows an app to programmatically set device lock-screen policy criteria, and android.permission.RECEIVE_BOOT_COMPLETED. Combined with the directBootAware Firebase initialization documented in C2, the national eID app is active and holds access to device security parameters from the very first boot of the device, before any user interaction. RFI-IRFOS could not identify a published Data Protection Impact Assessment (Art. 35 GDPR) covering this specific permission profile in combination with the pre-unlock Firebase infrastructure.

Impact Analysis

C1 and C2 share what makes this report different from a typical consumer-app audit: the operator is the state itself, and the affected population is, by design, nearly the entire adult citizenry. A hardcoded API key or a pre-consent SDK initialization is a finding RFI-IRFOS documents regularly across this disclosure programme; what changes the severity calculus here is that the system in question is the sole legal mechanism by which nine million people sign documents, authenticate to government services, and access their own health records. RFI-IRFOS explicitly escalated both C1 and C2 beyond where an equivalent finding would sit in a consumer app, and has said so in the findings themselves, per its own blast-radius escalation discipline, rather than silently inflating the rating.

H1 and H2 are the structural consequence of C2: once Google infrastructure is active before device unlock, both the transfer-documentation question (H1) and the permission-combination question (H2) follow directly from it. Notably, the same application gets a great deal right elsewhere, certificate pinning across every relevant eID domain, allowBackup disabled, no advertising SDKs, no PRC-linked SDKs, RootBeer root detection present, and cleartext traffic fully disabled at the network-security-config base level, which makes the four findings in this report more conspicuous, not less: a team capable of that level of care left a hardcoded key and a pre-unlock Google initialization in a national identity system.

The Complete Chain: A Disclosure That Bounced Three Times Before Reaching a Human Inbox at All

Step 1 – First attempt, outright failure: RFI-IRFOS sends the original six-finding disclosure on 19 June 2026 to sicherheit@digitalesamt.gv.at, CC A-Trust, BCC the Austrian Datenschutzbehoerde and CERT.at. The address bounces with repeated delays from 20 to 22 June, then permanently on 23 June 2026. The disclosure never reaches a human inbox on this attempt.

Step 2 – Second attempt, also fails: On 27 June 2026, RFI-IRFOS redelivers to post@digitalesamt.gv.at, CC datenschutz@digitalesamt.gv.at and pressedienst@bka.gv.at. pressedienst@bka.gv.at bounces immediately; the other two addresses bounce permanently by 3 July 2026.

Step 3 – Third attempt, also fails: On 30 June 2026, RFI-IRFOS redelivers to datenschutz@digitalesamt.gv.at and kommunikation@digitalesamt.gv.at. Both addresses bounce permanently by 3 July 2026. Three attempts, four weeks, zero successful deliveries to any digitalesamt.gv.at address.

Step 4 – Fourth attempt, first confirmed delivery: On 4 August 2026, 46 days after the original disclosure, RFI-IRFOS redelivers the complete findings to datenschutz@bka.gv.at, the data-protection contact published on id-austria.gv.at itself, CC post.szrb@bka.gv.at, the Austrian Datenschutzbehoerde, and CERT.at. No bounce follows. This is the first confirmed delivery in the entire case.

Step 5 – Thirty days of silence, a follow-up: On 3 September 2026, RFI-IRFOS follows up, restating the three original yes/no questions and setting a response deadline of 17 September 2026. No reply follows.

Step 6 – Deadlines pass: The 17 September 2026 question deadline passes unanswered, as does the 28 September 2026 coordinated-disclosure embargo stated in the redelivered findings.

Step 7 – Publication: This report publishes 19 days after the embargo date. Across 120 days since the original disclosure attempt and 74 days since the first confirmed delivery, five messages were sent across four delivery attempts. The Bundeskanzleramt and the Digitales Amt have never substantively replied. The only party to respond at all, A-Trust, did so for its own separate, already-published case, and could not substitute for a response from the system's actual operator.

Data Protection – Article by Article

Art. 32(1)(b), Art. 5(2) GDPR – Security of processing, accountability: C1's hardcoded, unrestricted Firebase API key falls short of the technical measures Art. 32 requires, and the burden of proving it is not exploitable rests with the operator under Art. 5(2).

Art. 6(1), Art. 5(1)(a) GDPR – Lawfulness of processing, transparency: C2's pre-unlock Firebase and ML Kit initialization transmits data before any user interaction that could constitute a legal basis.

Art. 44-49, Art. 28 GDPR – Transfers outside the EU, processor agreements: H1's Firebase Cloud Messaging delivery of official government notices has no documented transfer mechanism or Art. 28-compliant processing agreement identified for this specific purpose.

Art. 35 GDPR – Data protection impact assessment: H2's device-policy permission combination, active from first boot alongside pre-unlock Google infrastructure, has no published DPIA identified covering this specific combination.

Regulatory & Legal Landscape

ID Austria is operated by the Republik Österreich through the Bundeskanzleramt and its Digitales Amt, placing it under the Austrian Datenschutzbehoerde's direct jurisdiction, CC'd throughout this correspondence from the original disclosure onward, alongside CERT.at.

Fine exposure under GDPR: Art. 83(4) applies to the Art. 32 and Art. 28 issues in C1 and H1, up to EUR 10,000,000 or 2% of total worldwide annual turnover; Art. 83(7) GDPR specifically extends administrative fine powers of the Austrian Datenschutzbehoerde to public bodies, a power the authority has already exercised against public-sector operators. C1 (a hardcoded API key on critical federal infrastructure) is a clear Art. 32 violation; C2 (data transmission to Google LLC before any user interaction on a national eID system) engages Art. 6(1) directly; H1 (official communications via US infrastructure with no documented Art. 44-49 mechanism) is a standalone violation. The combination of all four findings on a system also used for ELGA health-record access (Art. 9 GDPR) is, in RFI-IRFOS's assessment, the kind of combination a supervisory authority is likely to find squarely within its review mandate.

Indicators of Compromise

The following identifiers, manifest declarations, and credentials were extracted from the production APK via static analysis only. No Bundeskanzleramt, Digitales Amt, or BRZ servers, accounts, or infrastructure were probed.

```
C1 -- Firebase API key: AIzaSyCLu46GzFY6qxDpR_6MxsDDA_HK30-EVXM
  project: digitalesamt, SHA-256 of analysed APK:
  00bac31cbde35cca3c8be7a2547b3caf5e0b78d600707490d7f2e0e4ad92d0e8

C2 -- FirebaseInitProvider + MlKitInitProvider, both directBootAware="true"

H1 -- Firebase Cloud Messaging confirmed in app privacy text for official
  government push notifications

H2 -- MANAGE_DEVICE_POLICY_LOCK_CREDENTIALS + RECEIVE_BOOT_COMPLETED
```

Disclosure Timeline & Outcome

2026-06-19 Original six-finding disclosure sent to sicherheit@digitalesamt.gv.at, CC A-Trust, BCC the Austrian Datenschutzbehoerde and CERT.at. Permanently bounces 2026-06-23.

2026-06-27 Redelivery to post@digitalesamt.gv.at, CC datenschutz@digitalesamt.gv.at and pressedienst@bka.gv.at. All bounce permanently by 2026-07-03.

2026-06-30 Redelivery to datenschutz@digitalesamt.gv.at and kommunikation@digitalesamt.gv.at. Both bounce permanently by 2026-07-03.

2026-08-04 Redelivery to datenschutz@bka.gv.at, CC post.szrb@bka.gv.at, the Austrian Datenschutzbehoerde, and CERT.at. No bounce. First confirmed delivery, REF DIGAMT-2026-002. Embargo stated as 2026-09-28.

2026-09-03 Follow-up sent, 30 days since confirmed delivery, restating three unanswered questions, deadline set for 2026-09-17. No reply.

2026-09-17 Question deadline passes unanswered.

2026-09-28 Embargo date reached. Correspondence record: five RFI-IRFOS messages across four delivery attempts, zero substantive replies from the Bundeskanzleramt or the Digitales Amt.

2026-10-17 This report published, 19 days after the embargo date. All four findings confirmed unaddressed on the basis of the correspondence record.

Residual Risk & Recommendations

C1 – Immediate: rotate AIzaSyCLu46GzFY6qxDpR_6MxsDDA_HK30-EVXM, restrict the replacement key to the production APK's certificate fingerprint in Google Cloud Console, and implement Firebase App Check.

C2 – Immediate: remove android:directBootAware="true" from the Firebase and ML Kit providers, or gate their initialization behind explicit post-unlock user interaction.

H1 – Near-term: document the specific Art. 44-49 transfer mechanism (Standard Contractual Clauses or equivalent) covering Firebase Cloud Messaging's handling of official government notification metadata, and name Google LLC and the United States explicitly in the app's privacy text for this purpose.

H2 – Near-term: publish a Data Protection Impact Assessment covering the MANAGE_DEVICE_POLICY_LOCK_CREDENTIALS and RECEIVE_BOOT_COMPLETED permission combination in light of C2's pre-unlock Google infrastructure initialization.

Across all findings: establish a monitored, reachable security and data-protection contact address for ID Austria independent of the digitalesamt.gv.at mail infrastructure that bounced three consecutive delivery attempts over four weeks, a availability gap that would equally have blocked a report from any citizen, researcher, or journalist, not only from RFI-IRFOS.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling (apktool, strings, baksmali). No Bundeskanzleramt, Digitales Amt, or BRZ servers, accounts, or infrastructure were probed. Technical evidence is archived under chain of custody and will be provided to regulatory authorities on request. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF ID-AUSTRIA-2026.